

LEXICON

Enterprise Password Risk Intelligence & Identity Security Platform

Platform Version: 1.0.0 (Enterprise GA)	Dataset Scope: 50,000 Active Directory Accounts
Frontend: Next.js 15, React 19, TypeScript, Tailwind	Backend: FastAPI, Uvicorn, Python 3.9+, Pydantic v2
Cryptography Engine: hash-wasm (WASM Multi-Worker)	Breach Telemetry: Synthetic Bulk + Live HIBP k-Anonymity

1. Executive Summary & Problem Space

Modern enterprise identity security is plagued by isolated password evaluation. Traditional password tools check whether a string has uppercase letters, numbers, or passes an arbitrary 8-character threshold. They fail to assess how passwords interact with organizational structure, administrative access, and lateral movement.

Lexicon redefines password auditing from static string scoring into comprehensive **Identity Risk Intelligence**. Benchmarked against an enterprise Active Directory directory of 50,000 corporate identities, Lexicon correlates: (1) Multi-account password reuse families, (2) Administrative privilege weighting, (3) Known breach exposure, (4) Real client-side mutation attack exploitability, and (5) Cryptographic hashing resistance across legacy and modern algorithms.

2. System Architecture & Zero-Marginal-Cost Compute

Lexicon introduces a hybrid compute architecture specifically engineered to deliver instant enterprise-scale analysis without requiring GPU cracking clusters or risking employee credential privacy:

- **Server-Side Telemetry Engine (FastAPI):** Handles precomputed enterprise audit indexes, fast paginated queries, cluster relationships, and CISO advisory report generation. Response times remain under 15ms.
- **Client-Side Compute Engine (WebAssembly & Web Workers):** All active cryptographic hashing, candidate mutation generation, and dictionary simulations execute directly on the operator's device using hash-wasm. This achieves true zero marginal server compute cost and horizontal scalability.
- **Zero-Knowledge Privacy Guarantee:** Raw password candidate streams and generated dictionary mutations are strictly confined to client browser memory. Only final execution summaries (probes tested, elapsed time, match status) are sent to the API.

3. Enterprise Active Directory Directory & Credential Reuse Clustering

- **Directory Structure:** 50,000 corporate accounts benchmarked across 8 corporate departments: Information Technology (6,250), Database Administration (3,120), Software Engineering (12,480), Finance & Accounting (6,250), Operations (9,400), Human Resources (4,100), Legal & Compliance (3,150), and Executive Leadership (5,250).
- **The Salted Reuse Paradox:** Salted algorithms (bcrypt/Argon2id) generate completely different hashes for identical passwords, which blinds traditional hash-equality auditing to credential reuse. Lexicon solves this by analyzing credential group identifiers, allowing exact tracking of **805 credential reuse families** without compromising salt mechanics.
- **Hero Account (alex.morgan - ACC-00042):** Enterprise Active Directory Domain Admin in IT Operations. Shares credentials with 31 accounts across IT, Finance, and Operations in **Cluster #42**, illustrating lateral privilege escalation.

4. Two-Stage Deterministic Risk-Scoring Methodology

Stage 1: Baseline Risk Calculation (Precomputed for all 50k accounts):

Baseline Risk = 0.30 · (1 - zxcvbn_norm) + 0.25 · BreachFlag + 0.20 · ReuseCluster_norm + 0.15 · PrivilegeWeight + 0.10 · PolicyViolations

- zxcvbn_norm: Score from 0 to 4 normalized to [0, 1.0].
- BreachFlag: 1.0 if matched in compromised breach corpus, else 0.0.

- ReuseCluster_norm: Normalized cluster size factor: $\min(1.0, \text{cluster_size} / 30.0)$.
- PrivilegeWeight: 1.0 for Domain/Cloud Admins & Executives, 0.4 for standard users.
- PolicyViolations: $\min(1.0, \text{count} / 3.0)$ for AD policy breaches.

Risk Tiers: Critical (≥ 0.75), High (≥ 0.50), Medium (≥ 0.25), Low (< 0.25).

Stage 2: Empirical Attack Adjustment (Applied after Attack Lab run):

Attack Adjustment = +0.15 (if cracked within budget) + ConfidenceBonus(speed, candidates, algo)

Final Account Risk = Baseline Risk + Attack Adjustment

An account's attack adjustment remains strictly 0.0 until an operator explicitly subjects it to an Attack Lab run.

5. Client-Side Bounded Attack Lab & Mutation Engine

The Attack Lab provides empirical verification of exploitability by running deterministic mutation rules inside a Web Worker:

- **Contextual Seed Extraction:** Extracts contextual seed terms from account metadata (username components, department name, company keywords).
- **Rule Combinations:** Applies TitleCase, UPPERCASE, toggleCase, leetspeak (@, 4, 3, 1, !, 0, \$, 5), calendar year suffixes (2022 to 2027), seasonal patterns (Summer!, Winter2026!), and special delimiter appends.
- **Dual Safety Caps:** Maximum 50,000 candidates tested or 30.0 seconds wall-clock time limit.
- **Exhaustion Semantics:** If no match is found within budget, the engine explicitly reports **'NOT FOUND WITHIN BOUNDED BUDGET'** rather than falsely certifying password strength.

6. WASM Multi-Algorithm Hash Race Arena

Lexicon conducts genuine, un-fabricated benchmarks directly on the operator's CPU across 4 cryptographic schemes using WebAssembly:

Algorithm	Type & Resistance	Parameters / Work Factor	Throughput / Security Implication
MD5	Unsalted Message Digest	1 Iteration, 0 KB RAM	100,000+ hashes/sec. Trivial to crack on commodity GPU.
SHA-256	Cryptographic Hash	1 Iteration, 0 KB RAM	High throughput. Vulnerable to ASIC/GPU dictionary parallelism.
bcrypt	Adaptive CPU Key Derivation	Cost Factor 10 (1,024 rounds), 4 KB RAM	Calibrated CPU cost slows brute force significantly.
Argon2id	Memory-Hard (OWASP Winner)	t=2, m=8,192 KB, p=1	High memory hardness defeats GPU/ASIC parallelism entirely.

7. Dual-Path Breach Exposure Engine

- **Path 1 — Offline Synthetic Corpus (Bulk 50k Audit):** An in-memory hash set of ~1,000 compromised credential signatures enabling instantaneous, offline O(1) breach correlation for all 50,000 accounts without external rate limits.
- **Path 2 — Live Real-World HIBP k-Anonymity API:** Single-password interactive probe. Computes the SHA-1 hash client-side and transmits **only the first 5 hexadecimal characters** to `https://api.pwnedpasswords.com/range/{prefix}`. The browser matches the remaining suffix locally, guaranteeing that the user's password never leaves the client.

8. AI & Deterministic CISO Remediation Studio

Converts deterministic mathematical audit findings into structured, prioritized enterprise remediation plans:

- **Executive Risk Summary:** CISO-level briefings detailing exposed privileged identities and blast radius metrics.
- **Active Directory Fine-Grained Password Policies (FGPP):** Mandating 16+ character passphrases, eliminating arbitrary 90-day resets.
- **Custom AD Wordlist Blocklists:** Automatic extraction of organization dictionary roots (e.g. Company*, Welcome*, Summer*).
- **Phishing-Resistant MFA Roadmap:** Priority deployment of hardware security keys (FIDO2 / WebAuthn) for privileged administrative accounts.
- **Deterministic Fallback:** Fully operational offline even in air-gapped environments without external LLM API dependencies.

9. Multi-Experience Frontend Architecture

Built in Next.js 15 using Apple-inspired minimalist design tokens, responsive cards, and dynamic Framer Motion transitions:

1. **Public Product Landing Page:** Interactive security posture overview, platform feature showcase, and architecture breakdown.
2. **Employee Self-Service Security Portal:** Live password strength calculator, policy violation diagnostics, and breach check.
3. **SOC Admin Operations Cockpit:** Unified Defense Readiness Dial, Risk Distribution charts, filterable 50k Account Directory,

Blast Radius Visualizer, Web Worker Attack Lab, and WASM Hash Race Arena.

10. Complete REST API Specification

HTTP	Endpoint	Query / Payload	Description
GET	/api/dataset/summary	None	Aggregated 50k audit metrics, tier counts, & top reuse families
GET	/api/dataset/hero-account	None	Retrieves primary demo target: alex.morgan (Cluster #42)
GET	/api/dataset/accounts	search, tier, dept, is_privileged, page	Paginated directory search and multi-vector filtering
GET	/api/dataset/accounts/{id}	account_id in path	Detailed telemetry, hashes, & policy violations for an identity
GET	/api/dataset/reuse-clusters/{id}	group_id in path	Full member list and departmental blast radius for a cluster
POST	/api/attack/result	account_id, algorithm, candidates, matched	Ingests client attack metadata & applies empirical risk adjustment
POST	/api/remediation/report	findings JSON	Generates structured CISO remediation & policy recommendations
GET	/api/hibp/check-range/{prefix}	5-char hex prefix in path	Proxies 5-char SHA-1 prefix to HIBP k-Anonymity API
GET	/health	None	Service health status check

11. Quality Assurance & Local Quick Start

- **Automated Test Suite:** 17 unit and integration test suites passing (pytest -v) covering mathematical risk thresholds, hashing verifications, Active Directory policy parsers, and API contracts.
- **Start Backend:** cd backend && python -m uvicorn backend.app.main:app --host 0.0.0.0 --port 8000 --reload
- **Start Frontend:** cd frontend && npm run dev (Open <http://localhost:3000>)
- **API Docs:** Interactive Swagger UI at <http://localhost:8000/docs>.